

防火墙

3. 防火墙技术

防火墙（Firewall）是建立在内外网络边界上的过滤封锁机制，它认为内部网络是安全和可信赖的，而外部网络是不安全和不可信赖的。防火墙的作用是防止不希望的、未经授权地进出被保护的内部网络，通过边界控制强化内部网络的安全策略。防火墙作为网络安全体系的基础和核心控制设施，贯穿于受控网络通信主干线，对通过受控干线的任何通信行为进行安全处理，如控制、审计、报警和反应等，同时也承担着繁重的通信任务。由于其自身处于网络系统中的敏感位置，自身还要面对各种安全威胁，因此，选用一个安全、稳定和可靠的防火墙产品，其重要性不言而喻。

防火墙技术经历了包过滤、应用代理网关和状态检测技术三个发展阶段。

1) 包过滤防火墙

包过滤防火墙一般有一个包检查块（通常称为包过滤器），数据包过滤可以根据数据包头中的各项信息来控制站点与站点、站点与网络、网络与网络之间的相互访问，但无法控制传输数据的内容，因为内容是应用层数据，而包过滤器处在网络层和数据链路层（即 TCP 和 IP 层）之间。通过检查模块，防火墙能够拦截和检查所有出站和进站的数据，它首先打开包，取出包头，根据包头的信息确定该包是否符合包过滤规则，并进行记录。对于不符合规则的包，应进行报警并丢弃该包。

过滤型的防火墙通常直接转发报文，它对用户完全透明，速度较快。其优点是防火墙对每条传入和传出网络的包实行低水平控制；每个 IP 包的字段都被检查，例如源地址、目的地址、协议和端口等；防火墙可以识别和丢弃带欺骗性源 IP 地址的包；包过滤防火墙是两个网络之间访问的唯一来源；包过滤通常被包含在路由器数据包中，所以不需要额外的系统来处理这个特征。缺点是不能防范黑客攻击，因为网管不可能区分出可信网络与不可信网络的界限；不支持应用层协议，因为它不识别数据包中的应用层协议，访问控制粒度太粗糙；不能处理新的安全威胁。

2) 应用代理网关防火墙

应用代理网关防火墙彻底隔断内网与外网的直接通信，内网用户对外网的访问变成防火墙对外网的访问，然后再由防火墙转发给内网用户。所有通信都必须经应用层代理软件转发，访问者任何时候都不能与服务器建立直接的 TCP 连接，应用层的协议会话过程必须符合代理的安全策略要求。

应用代理网关的优点是可以检查应用层、传输层和网络层的协议特征，对数据包的检测能力比较强。缺点是难以配置；处理速度非常慢。

3) 状态检测技术防火墙 **第三个防火墙没考过 作简单的了解即可**

状态检测技术防火墙结合了代理防火墙的安全性和包过滤防火墙的高速度等优点，在不损失安全性的基础上，提高了代理防火墙的性能。

状态检测防火墙摒弃了包过滤防火墙仅考查数据包的 IP 地址等几个参数而不关心数据包连接状态变化的缺点，在防火墙的核心部分建立状态连接表，并将进出网络的数据当成一个个的会话，利用状态表跟踪每一个会话状态。状态监测对每一个包的检查不仅根据规则表，更考虑了数据包是否符合会话所处的状态，因此提供了完整的对传输层的控制能力，同时也改进了流量处理速度。因为它采用了一系列优化技术，使防火墙性能大幅度提升，能应用在各种网络环境中，尤其是在一些规则复杂的大型网络上。

一个防火墙系统通常是由过滤路由器和代理服务器组成。过滤路由器是一个多端口的 IP 路由器，它能够拦截和检查所有出站和进站的数据。代理服务器防火墙使用一个客户程序与特定的中间结点（防火墙）连接，然后中间结点与期望的服务器进行实际连接。这样，内部与外部网络之间不存在直接连接，因此，即使防火墙发生了问题，外部网络也无法获得与被保护的网络的连接。典型防火墙的体系结构分为包过滤路由器、双宿主主机、屏蔽主机网关和被屏蔽子网等类型。

病毒

病毒：

计算机病毒的特征包括：传播性、隐蔽性、感染性、潜伏性、触发性、破坏性等

Worm表示蠕虫病毒、**Trojan**表示特洛伊木马、**Backdoor**表示后门病毒、**Macro**表示宏病毒

宏病毒感染的对象主要是文本文档、电子表格等

木马软件：冰河

蠕虫病毒：欢乐时光、熊猫烧香、红色代码、爱虫病毒、震网

网络攻击

网络攻击

拒绝服务攻击（**Dos**攻击）：目的是使计算机或网络无法提供正常的服务
拒绝服务攻击是不断向计算机发起请求来实现的

重放攻击：攻击者发送一个目的主机已经接受过的报文来达到攻击目的
攻击者利用网络监听或者其他方式盗取认证凭据，之后再重新发送给认证服务器。
主要用于身份认证过程，目的是破坏认证的正确性。

口令入侵攻击：使用某些合法用户的账号和口令登录到目的主机，然后再实施攻击活动

特洛伊木马：被伪装成程序或游戏，当用户下载了带有木马的软件或附件时，这个程序就会向黑客发起连接请求，建立连接后黑客就实施攻击活动。

端口欺骗攻击：采用端口扫描找到系统漏洞从而实施攻击

网络监听：攻击者可以接收某一网段在同一条物理通道上传输的所有信息，
使用网络监听可以轻松截取包括账号和口令在内的信息资料

IP欺骗攻击：产生的**IP**数据包为伪造的源**IP**地址，以便冒充其他系统或发件人的身份。

Sql注入攻击：是黑客对数据库进行攻击的常用手段之一。
没有对用户输入数据的合法性进行判断，使应用程序存在安全隐患。
攻击者可以提交一段数据库查询代码，根据程序返回的结果，获得某些他想得知的数据，
首先获取数据库的权限，就可获取用户账号和口令信息，以及对某些数据修改等。

入侵检测技术：专家系统、模型检测、简单匹配

网络安全

SSL (Secure Socket Layer, 安全套接层) 是 Netscape 于 1994 年开发的传输层安全协议, 用于实现 Web 安全通信。1996 年发布的 SSL 3.0 协议草案已经成为一个事实上的 Web 安全标准。**SSL 端口号: 443**

TLS (Transport Layer Security, 传输层安全协议) 是 IETF 制定的协议, 它建立在 SSL 3.0 协议规范之上, 是 SSL 3.0 的后续版本。

终端设备与远程站点之间建立安全连接的协议是 SSH。SSH 为 Secure Shell 的缩写, 是由 IETF 制定的建立在应用层和传输层基础上的安全协议。SSH 是专为远程登录会话和其他网络服务提供安全性的协议。利用 SSH 协议可以有效防止远程管理过程中的信息泄露问题。SSH 最初是 UNIX 上的程序, 后来又迅速扩展到其他操作平台。

HTTPS (Hyper Text Transfer Protocol over Secure Socket Layer), 是以安全为目标的 HTTP 通道, 即使用 SSL 加密算法的 HTTP。

MIME (Multipurpose Internet Mail Extensions, 多用途互联网邮件扩展类型) 是一个互联网标准, 扩展了电子邮件标准, 使其能够支持: 非 ASCII 字符文本, 非文本格式附件 (二进制、声音、图像等), 由多部分 (multiple parts) 组成的消息体, 包含非 ASCII 字符的头信息 (Header information)。

PGP (Pretty Good Privacy, 优良保密协议) 是一个基于 RSA 公匙加密体系的邮件加密软件。可以用它对邮件保密以防止非授权者阅读, 还能对邮件加上数字签名从而使收信人可以确认邮件的发送方。